

모바일 및 네트워크 관련 공격



학습내용

- 네트워크 기반 공격
- 무선 네트워크 공격
- 모바일 공격

학습목표

- 네트워크 기반 공격의 탐지 및 대응을 수행할 수 있다.
- 무선 네트워크 공격의 안전한 암호방식을 적용할 수 있다.
- 모바일 공격의 취약점을 파악하여 이에 대응할 수 있다.

네트워크 기반 공격

1. 네트워크 기반 공격 분류

서비스 거부 공격	서버의 자원을 소비시켜 시스템을 다운
네트워크 스캐닝	공격전 취약점 파악
네트워크 공격	네트워크 패킷 도청 · 감청

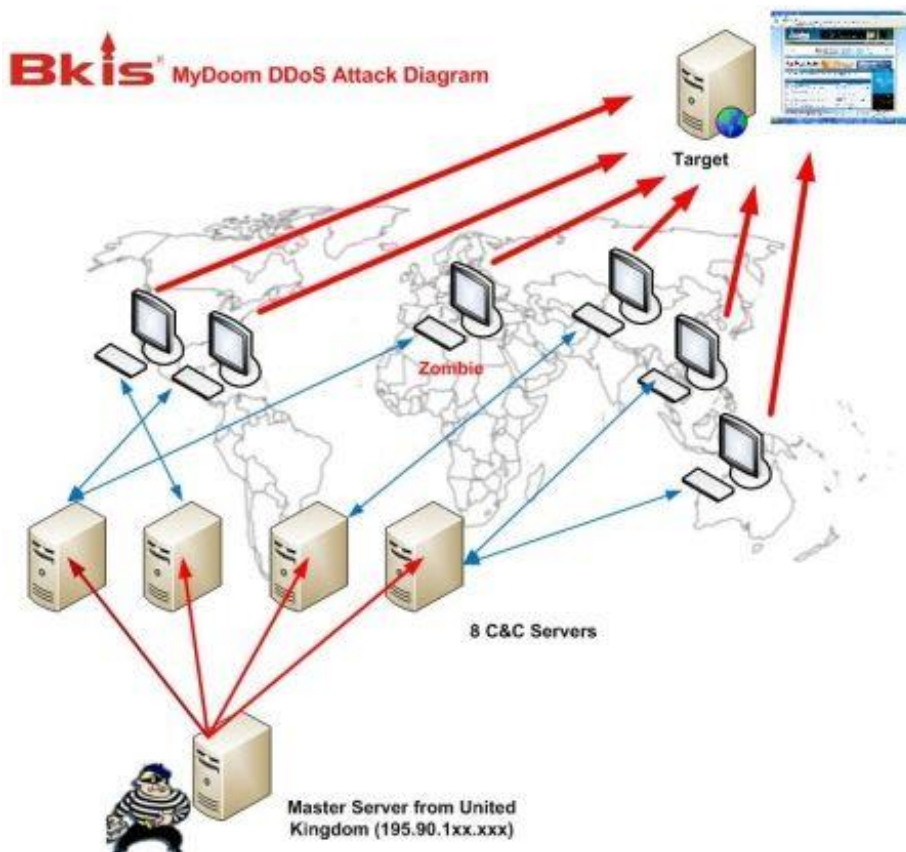
공격 종류	공격 기법
서비스 거부 공격	Dos, DDos
	SYN Flooding
	UDP Flooding
	Land 공격
	Ping of Death
	Smurf 공격
	Tear Drop 공격
	Tiny Fragment 공격
	Fragment Overlap 공격
네트워크 스캐닝	TCP SYN 스캔
	UDP Scan
네트워크 공격	스니핑(Sniffing)
	스푸핑(Spoofing)
	세션 하이재킹(Session Hijacking)

🔑 네트워크 기반 공격

2. 공격 기법의 종류별 특징

1) DoS, DDoS

- 서비스 거부 공격 : 과도한 트래픽 또는 시스템의 자원을 고갈시켜 시스템을 불능 상태에 빠트리는 공격



출처: <http://noxioushackerz.blogspot.kr/2011/05/how-to-limit-denial-of-service-dos.html>

2. 공격 기법의 종류별 특징

1) DoS, DDoS

- 서비스 거부 공격(DoS)
 - ✓ 공격자가 시스템의 하드웨어나 소프트웨어 등을 무력하게 만들어 시스템의 정상적인 수행에 문제를 일으키는 행위
- 분산 서비스 거부 공격(DDoS)
 - ✓ 네트워크로 연결된 많은 수의 호스트들에 패킷을 범람시킬 수 있는 DoS용 프로그램을 분산 설치하여 이들이 서로 통합된 형태로 한 시스템을 집중적으로 공격

2. 공격 기법의 종류별 특징

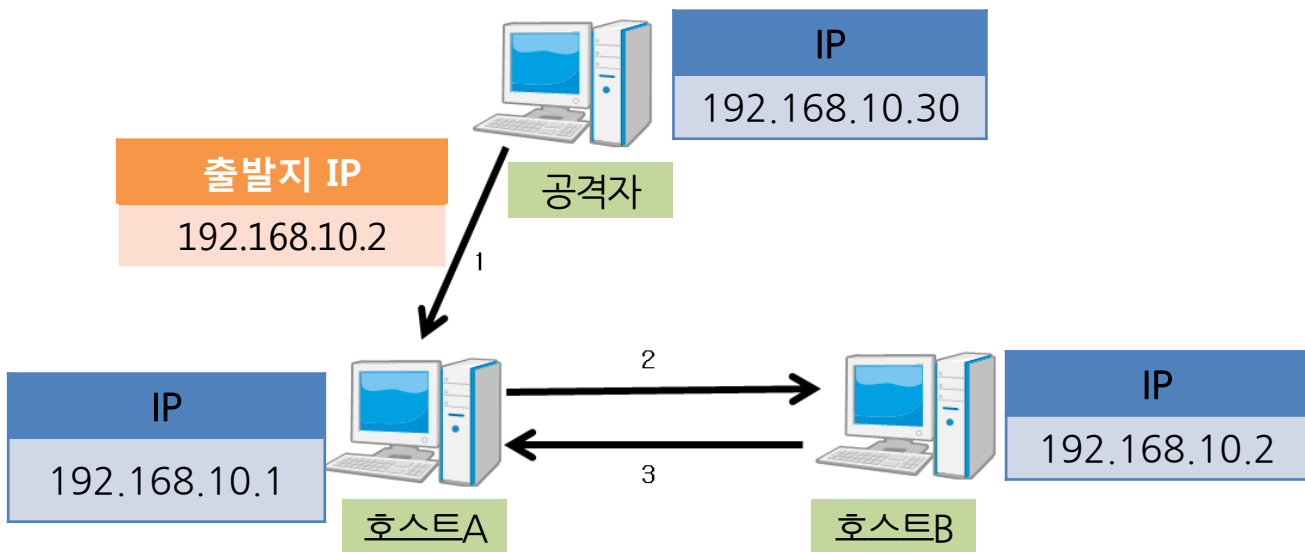
2) SYN/UDP Flooding

- SYN Flooding

- ✓ TCP 프로토콜의 구조적인 문제를 이용한 공격
- ✓ 각 서버의 동시 가용 사용자수를 SYN 패킷만 보내 점유하여 다른 사용자로 하여금 서버를 사용 불가능하게 하는 공격

- UDP Flooding

- ✓ 비연결성 및 비신뢰성으로 쓰리 웨이 핸드셰이킹을 하지 않음



2. 공격 기법의 종류별 특징

3) Ping of Death

- 핑(Ping)

✓ 네트워크상에서 데이터가 오고 가는 시간을 측정하는 명령어

[illegible]

- -t : 계속 패킷을 보냄
- -i : 버퍼 사이즈

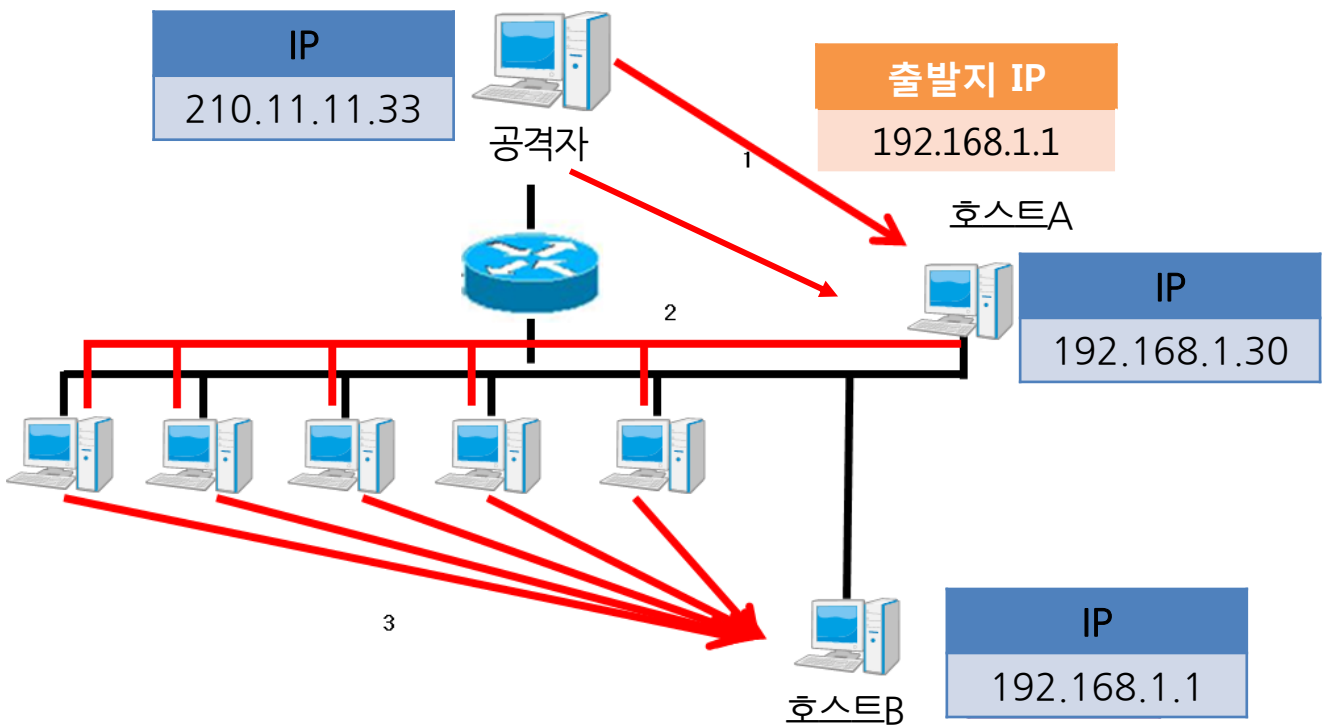
“호스트의 자원의 무의미한 소모 및 네트워크 성능 저하”

🔑 네트워크 기반 공격

2. 공격 기법의 종류별 특징

4) Smurf 공격

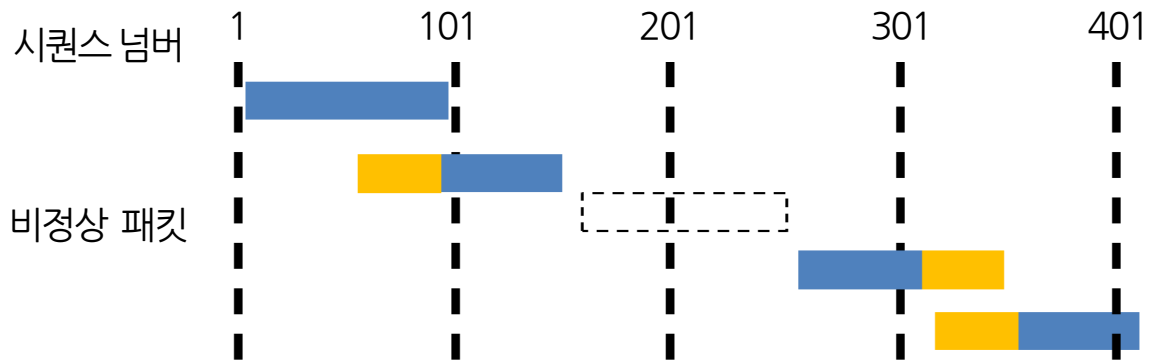
- ICMP 에코 패킷을 브로드캐스트하여 ICMP 리퀘스트하게 만들어 공격



2. 공격 기법의 종류별 특징

5) Tear Drop 공격

- 공격자가 IP 패킷 조각의 위치를 위조 및 전송하여 시스템이 다운되는 현상

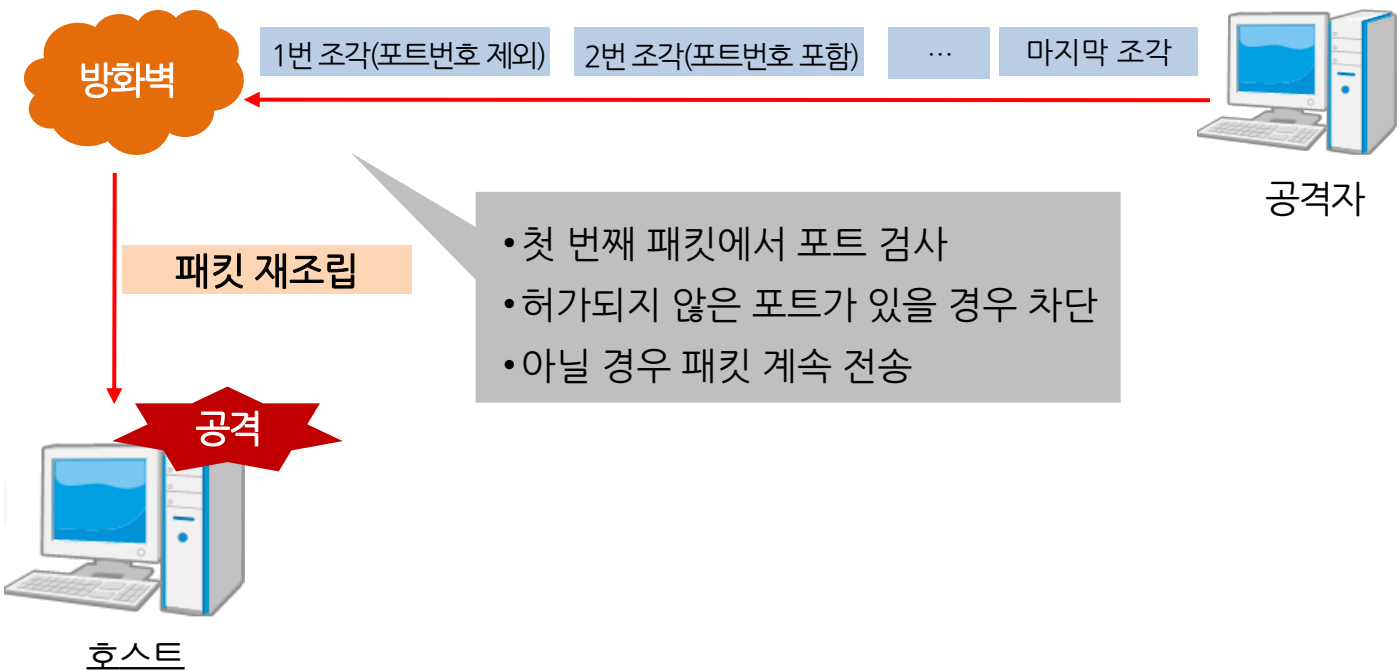


🔑 네트워크 기반 공격

2. 공격 기법의 종류별 특징

6) Tiny Fragment 공격

- 최초의 패킷 조각을 아주 작게 만들어 네트워크 침입탐지시스템(IDS)이나 패킷 필터링 장비를 우회하는 공격

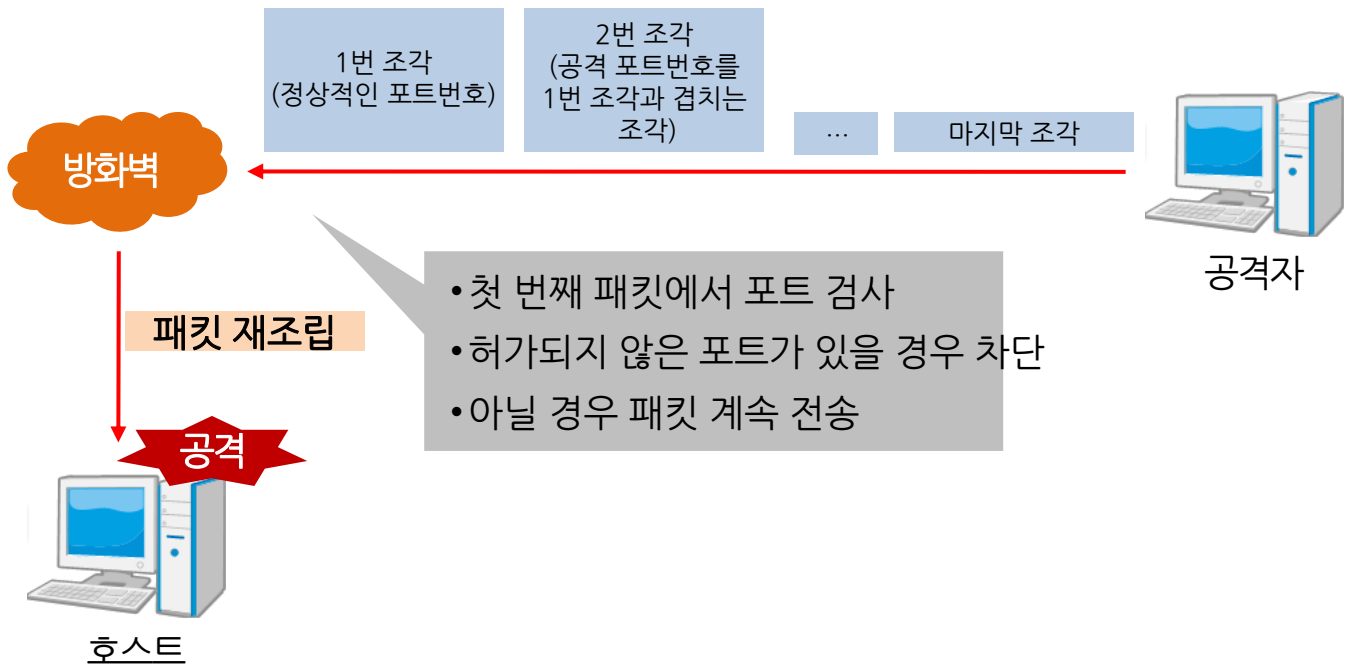


🔑 네트워크 기반 공격

2. 공격 기법의 종류별 특징

7) Fragment Overlap 공격

- Tiny Fragment Attack 기법에 비해 좀더 정교한 공격

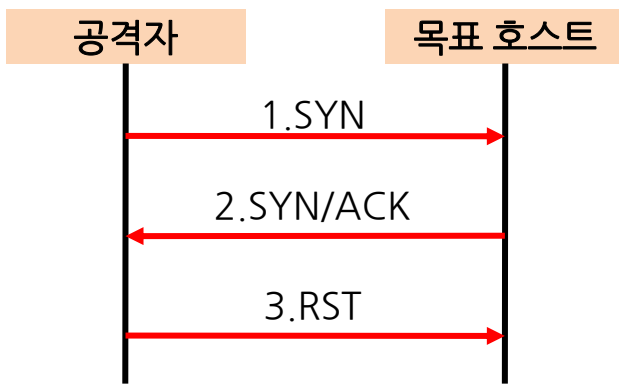


2. 공격 기법의 종류별 특징

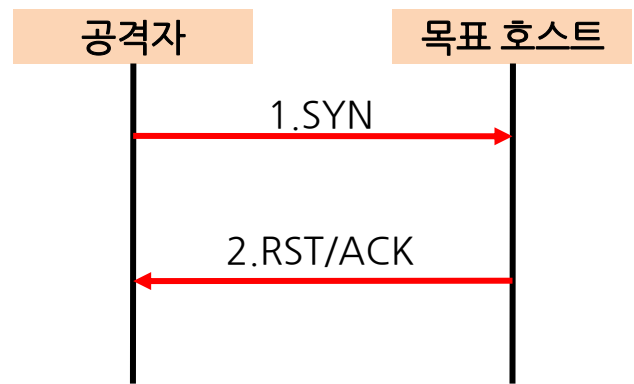
8) TCP SYN 스캔

- 특정 시스템의 포트로 SYN 패킷을 전송해 응답을 기다리는 방법

〈포트가 열려 있는 경우〉



〈포트가 닫혀 있는 경우〉



“스캔속도가 TCP 커넥트 스캔보다 빠름”

2. 공격 기법의 종류별 특징

9) 세션 하이재킹(Session Hijacking)

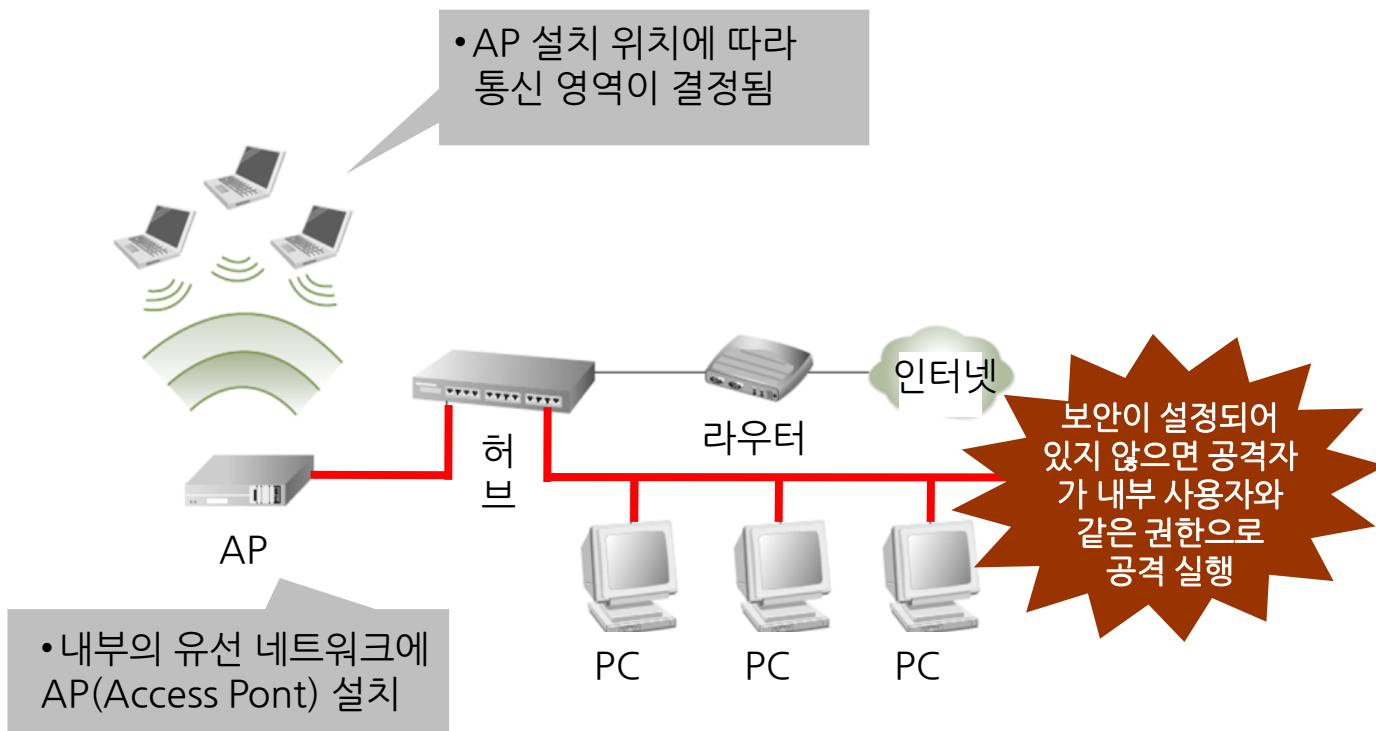
- TCP를 이용한 거의 모든 세션의 갈취가 가능한 기법

목표 설정	• 텔넷이나 FTP와 같이 세션 기반의 연결 설정이 가능한 서버를 목표로 함 • 시퀀스 넘버 샘플을 수집하기 전에 목표 시스템으로 접근이 가능함을 확인
시퀀스 넘버 난이도 검사	공격자가 세션을 하이재킹하고 트래픽 감시 및 가로채기를 수행하기 위해 우선적으로 시퀀스 넘버를 추측할 수 있어야 함
공격대상 세션 설정	탐지가 어렵도록 은밀히 수행되는 다른 종류의 공격들과 대조적으로 세션 하이재킹은 많은 트래픽이 존재할 때 탐지를 어렵게 만듦
시퀀스 넘버 추측	공격자는 세션을 성공적으로 가로채기 위해 시퀀스 넘버를 추측해야 함
사용자 시스템 다운	서비스 거부 공격을 수행하여 사용자 시스템을 오프라인 상태로 만듦

🔑 무선 네트워크 공격

1. 무선 네트워크 개요

“내부 네트워크 확장 및 편리한 인터넷 사용”



🔑 무선 네트워크 공격

1. 무선 네트워크 개요

- 무선 네트워크 전송 거리

무지향성 안테나

- 주로 봉의 형태, AP의 위치에 상관없이 동작
- **4개 이상의 방향성**을 가지고 있음
- 수평면에 대한 무지향성을 지원



지향성 안테나

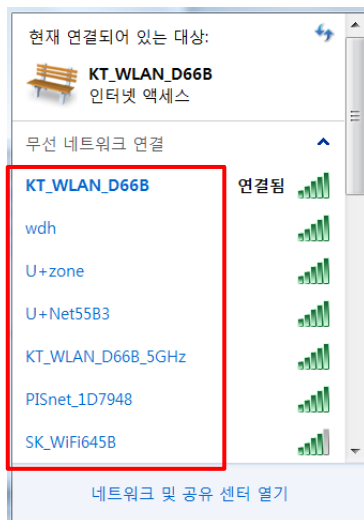
- 수직과 수평인 것으로 나뉨
- 목표 방향을 지정하여 그 방향으로만 전파를 탐지



2. 무선 네트워크 보안

1) AP 보안

- 물리적인 보안 및 관리자 패스워드 변경
 - ✓ 일반인이 쉽게 접근할 수 없도록 물리적인 통제 수행
 - ✓ 건물 내에 한정되도록 전파 출력 조정 필요함
 - ✓ 건물 안쪽의 중심부의 눈에 쉽게 띄지 않는 곳에 설치
 - ✓ 설치한 후에 AP의 기본 계정 패스워드는 반드시 재설정
- SSID 브로드캐스팅 금지
 - ✓ 무선 랜 식별 위한 SSID(Service Set Identifier) 사용
 - ✓ AP 목록에서 **이름으로 표시된 것이 SSID임** → 해당 패스워드를 입력하여 접속



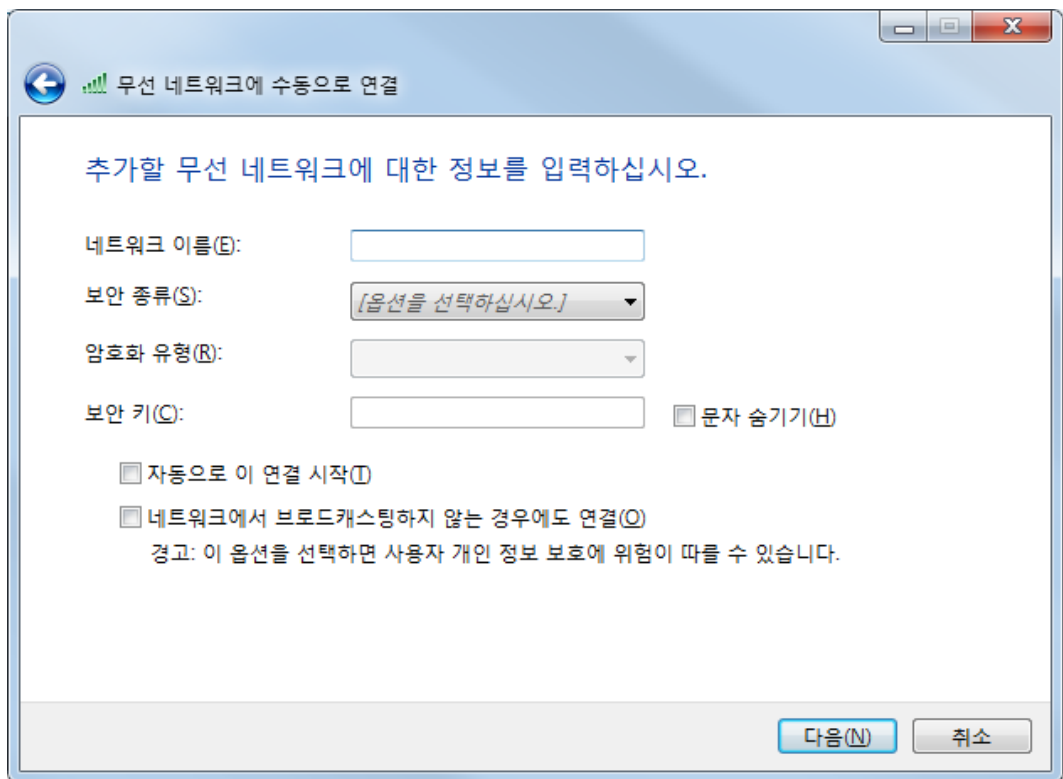
[무선 AP 목록]

“가장 설정하기 쉬운 보안 사항 :
SSID가 AP 탐색에 쉽게 노출되지
않도록 SSID의 브로드캐스팅을 막음”

2. 무선 네트워크 보안

1) AP 보안

- SSID 브로드캐스팅 금지
 - ✓ SSID를 직접 입력하여 AP에 접속하도록 함
 - ✓ 해당 AP의 존재를 숨기기 위해 SSID 브로드캐스팅 금지
 - ✓ SSID는 AP 접속을 위한 1차 패스워드로 사용됨



무선 네트워크에 수동으로 연결

추가할 무선 네트워크에 대한 정보를 입력하십시오.

네트워크 이름(E):

보안 종류(S):

암호화 유형(R):

보안 키(K): ☐ 문자 숨기기(H)

☐ 자동으로 이 연결 시작(I)

☐ 네트워크에서 브로드캐스팅하지 않는 경우에도 연결(O)

경고: 이 옵션을 선택하면 사용자 개인 정보 보호에 위험이 따를 수 있습니다.

다음(N) 취소

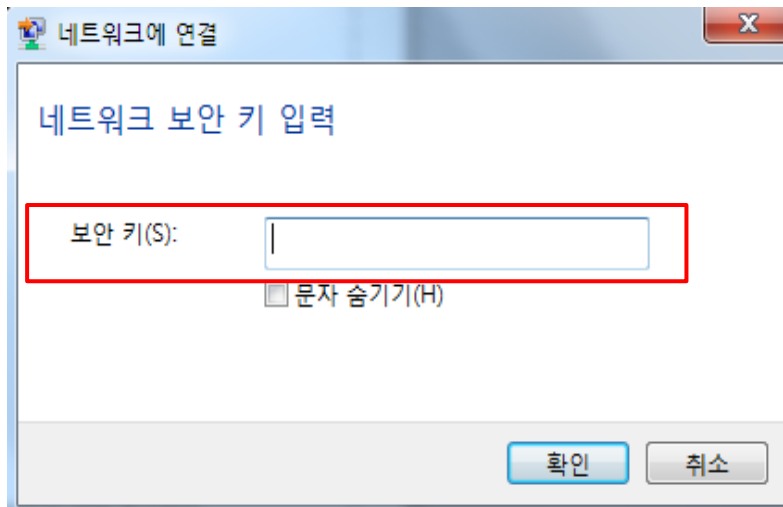
무선 네트워크 공격

2. 무선 네트워크 보안

2) 무선 랜 통신 암호화

- 인증 및 전송구간 암호화

✓ 네트워크에 대한 인증 및 통신 과정에서 데이터 유출을 막기 위함



2. 무선 네트워크 보안

2) 무선 랜 통신 암호화

▪ 무선 랜 암호 방식

WEP	• 128비트 키까지 암호화 키를 제공 • 해킹을 당할 위험성이 있음
WPA/WPA-PSK	• WEP의 보안 취약점에 대한 대안으로 나온 암호화 방식
EAP/802.1X	• 무선 랜 클라이언트와 RADIUS 서버간 통신을 가능하게 하는 프로토콜 • <u>암호화 키 복호화 가능성을 무력화시킴</u>
WEP/WPA-PSK	• 미리 양쪽에서 설정한 암호화 키를 사용

1. iOS의 보안과 취약점

1) iOS 보안 체계

“보안에 대한 기본적인 통제권을
애플이 소유”

안전한부팅 절차 확보

시스템 소프트웨어 개인화

응용 프로그램에 대한 서명

샌드박스(Sandbox) 활용

1. iOS의 보안과 취약점

1) iOS 보안 체계

▪ 안전한 부팅 절차 확보

- ✓ 모든 소프트웨어는 애플 암호화 로직의 서명된 방식에 의해 무결성이 확인된 후에만 동작
- ✓ iOS의 부팅 과정에도 동일하게 적용

▪ 시스템 소프트웨어 개인화

- ✓ 모든 소프트웨어는 애플의 아이튠즈를 통해 일괄적으로 배포
- ✓ 소프트웨어 설치/업데이트 시 시스템 소프트웨어 개인화 절차를 통해 통제
- ✓ 보안상의 문제가 있는 소프트웨어의 버전이 해커에 의해 배포되고 설치되는 것을 막기 위해 다운그레이드 금지
- ✓ 애플의 모든 단말기에 설치된 모든 응용 프로그램은 임의의 프로그램의 변경 및 설치가 통제

1. iOS의 보안과 취약점

1) iOS 보안 체계

▪ 응용 프로그램에 대한 서명

- ✓ iOS에 설치되는 모든 앱에 대해 코드 무결성 사인(Code Signature)을 등록하게 하고 있음
- ✓ 등록된 앱의 코드 무결성 사인이 다를 경우 앱을 설치하지 못하게 하는 것이 주 목적
- ✓ 개인이 각각의 iOS에 설치한 애플리케이션이 문제가 있을 경우 네트워크에 연결된 iOS를 강제로 삭제 가능

▪ 샌드박스(Sandbox) 활용

- ✓ 응용 프로그램이 실행될 때 원래의 운영체제와 완전히 독립되어 실행되는 형태를 의미
- ✓ 애플이 만든 앱은 샌드박스를 적용하지 않지만 기타 사용자 앱의 경우 샌드박스를 적용
- ✓ 사용자 앱의 경우 앱끼리 데이터를 주고 받을 수 없고, 시스템 파일에도 접근할 수 없음
- ✓ 앱끼리 문서나 음악 사진 등을 전송하는 것은 시스템 API에서 기능을 제공하는 경우에만 가능

1. iOS의 보안과 취약점

1) iOS 보안 체계

멀티태스킹 금지

- 음악을 듣는 것 이외의 멀티태스킹을 금지하고 있음
- 바이러스는 사용자가 컴퓨터를 사용하는 과정에서 실제로 사용하는 프로그램과 함께 백그라운드로 실행되는데, 그 가능성을 차단한 것

원격지에서 iOS 로그인 금지

- iOS를 구동하는 단말기에 http와 ftp의 단순한 파일 전송 기능 이외에 명령이 입력 가능한 형태의 응용 프로그램은 허용하지 않음

2) iOS 취약점

“외부에 대한 서비스를 제공하기 위해 특정한 인터페이스를 제공하는 부분이 거의 없음”



리눅스 등의 운영체제와 동일한 형태로 보안을 적용해야 함

2. 안드로이드의 보안과 취약점

1) 안드로이드 보안 체계

android

“공개적인 프로그램 개발 추구”

응용 프로그램의 권한 관리

응용 프로그램에 대한 서명

샌드박스 활용

2. 안드로이드의 보안과 취약점

1) 안드로이드 보안 체계

■ 응용 프로그램의 권한 관리

- ✓ 설치된 모든 응용 프로그램은 일반 사용자 권한으로 실행
- ✓ 사용자의 데이터에 접근할 때 모든 사항을 응용 프로그램 사양에 명시 및 사용자의 동의를 받음
- ✓ 모든 응용 프로그램은 설치 시 자신의 고유한 사용자 ID를 할당 받아 동작

■ 응용 프로그램에 대한 서명

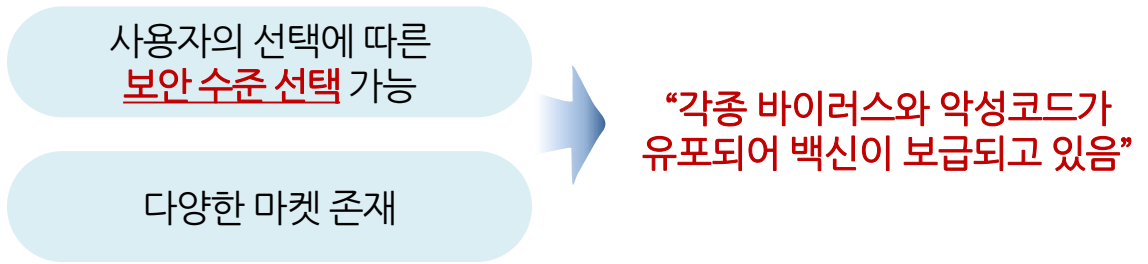
- ✓ 설치되는 응용 프로그램에 대해 서명을 하고 있음
- ✓ 개발자가 서명하도록 하고 있음
- ✓ 안드로이드에서의 전자서명은 응용 프로그램에 대한 통제권을 개발자가 가지게 하는 것이 목적

■ 샌드박스 활용

- ✓ 샌드박스 프로세스 내부에서 실행되나 특정 형태를 갖추어 권한을 요청하는 것을 허용
- ✓ 상대적으로 애플리케이션간 통신과 데이터 전달이 자유로움

2. 안드로이드의 보안과 취약점

2) 안드로이드 취약점



3. 모바일 기기 보안

- 모바일 기기 보안에서 가장 큰 문제 : 모바일 기기의 이동성
- 무선 랜의 경우 노트북을 수신율이 높은 안테나를 붙여서 차를 타고 보안이 취약한 무선 랜을 탐색하며 해킹을 시도할 수 있는데 이를 ‘워 드라이빙’이라고 함

“높은 수준의 암호화와 인증 구현이 어려워
다양한 위험에 노출될 수 있음”

블루프린팅
(Blueprinting)

블루스나프
(BlueSnarf)

블루버그
(BlueBug)

3. 모바일 기기 보안

- 블루프린팅(Blueprinting)

- ✓ 블루투스 공격 장치의 검색 활동
- ✓ 서비스 발견 프로토콜(SDP : Service Discovery Protocol)을 이용해 공격 가능한 블루투스 장치 검색 및 모델 확인

- 블루스나프(BlueSnarf)

- ✓ 장비의 임의 파일에 접근하는 공격
- ✓ OPP(OBEX Push Profile)를 사용해 정보 열람이나 취약한 장치 파일 접근

- 블루버그(BlueBug)

- ✓ 블루투스 장비간 취약한 연결 관리를 악용한 공격
- ✓ 한 번 연결되면 이후 다시 연결하지 않아도 서로 연결되는 취약점을 이용해 공격 수행

핵심요약

1. 네트워크 기반 공격의 종류

- 1) 서비스 거부 공격 : 서버의 자원을 소비시켜 시스템을 다운 시키는 공격
- 2) 네트워크 스캐닝 : 공격전 취약점 파악
- 3) 네트워크 공격 : 네트워크 패킷 도·감청

[대표적인 공격기법]

- SYN Flooding : SYN 패킷만 보내 서버를 사용 불가능하게 하는 공격
- UDP Flooding : UDP 패킷을 보내 네트워크 마비시키는 공격
- Land 공격 : 출발지 IP 주소를 변경하여 네트워크를 마비시키는 공격
- Ping of Death : 많은 단편화 작업을 이용한 공격
- Smurf 공격 : ICMP Echo 패킷을 브로드캐스트하여 네트워크를 마비시키는 공격
- Tear Drop 공격 : 패킷 오프셋을 변경하여 시스템을 마비시키는 공격
- Tiny Fragment 공격 : IP 단편화를 이용하여 침입탐지시스템을 우회하는 공격
- Fragment overlap 공격 : 패킷을 조작하여 침입탐지시스템을 우회하는 공격
- TCP SYN Scan : TCP 포트를 스캔
- 세션 하이재킹(Session Hijacking) : 세션을 가로채어 인증을 우회하는 공격

핵심요약

2. 무선 네트워크 공격

- 무선 네트워크에 보안이 설정되지 않으면 공격자가 통신 영역 안에서 내부 사용자와 같은 권한으로 공격을 실행
- AP 보안 방법
 - 물리적인 보안 및 관리자 패스워드 변경
 - SSID 브로드캐스팅 금지
- 무선 랜 통신 암호화
 - 인증 및 전송구간 암호화
 - 무선 랜 암호 방식 : WEP, WPA/WPA-PSK, EAP/802.1X, WEP/WPA-PS

핵심요약

3. 모바일 공격

- iOS 보안 체계

안전한 부팅 절차 확보, 시스템 소프트웨어 개인화, 응용 프로그램에 대한 서명, 샌드박스 활용 멀티태스킹 금지, 원격지에서 iOS 로그인 금지

- iOS 취약점

- iOS의 보안상의 문제점 : 대부분 탈옥(Jailbreak)한 iOS 기기에서 발생함
- 탈옥했을 경우 : 리눅스 등의 운영체제와 동일한 형태로 보안을 적용해야 함

- 안드로이드 보안 체계

- 응용 프로그램의 권한 관리, 응용 프로그램에 대한 서명, 샌드박스 활용

- 안드로이드 취약점

- 안드로이드 : 사용자의 선택에 따라 보안 수준 선택 가능
- 앱 마켓 : iOS는 하나로 통일되어 있는 반면 안드로이드는 다양한 마켓이 존재

- 블루투스의 취약점과 위협

- 블루프린팅(Blueprinting) : 블루투스 공격 장치의 검색 활동을 의미
- 블루스나프(BlueSnarf) : 블루투스의 취약점을 이용하여 장비의 임의 파일에 접근하는 공격
- 블루버그(BlueBug) : 블루투스 장비 간 취약한 연결 관리를 악용한 공격